PROYECTO RENIEC - BID
Mejoramiento del acceso a los servicios de registros civiles e identificación de calidad a nivel nacional

ESTÁNDAR DE CONTROLES CRIPTOGRÁFICOS

Mejoramiento de Acceso a los Servicios de Registros Civiles e Identificación de Calidad a Nivel Nacional (Contrato de Préstamo BID № 4297/OC-PE)

Componente 3: Incorporación de tecnologías para la prestación de los servicios

RENIEC
REGISTRO NACIONAL DE IDENTIFICACIÓN Y ESTADO CIVIL

Elaborado por:

Ing. Jarol Adolfo Bastidas Orihuela
Especialista en Arquitectura de Soluciones Senior

Ing. Gustavo Alfonso Montenegro Marcial
Especialista en Arquitectura de Soluciones Junior

Historial de modificaciones del Estándar de Controles Criptográficos

Versión	Fecha	Modificaciones	Preparado/Revisado por
1.0	01/04/2024	Versión inicial	Jarol Adolfo Bastidas Orihuela Gustavo Alfonso Montenegro Marcial
1.1	12/08/2025	Versión actualizada	Jarol Adolfo Bastidas Orihuela

REPÚBLICA DEL PERÚ
FIRMA DIGITAL

Firmado digitalmente por:
BASTIDAS ORIHUELA JAROL
ADOLFO FIR 40561133 hard
Motivo: Soy el autor del documento
Fecha: 15/09/2025 09:39:26-0500

MIGUEL ÁNGEL MARTÍNEZ LA ROSA
Jefe de la Unidad de Ingeniería de Software
REGISTRO NACIONAL DE IDENTIFICACION Y ESTADO CIVIL

Firmado digitalmente por:
MARTINEZ LA ROSA Miguel
Angel FAU 20295613620 soft
Motivo: En señal de conformidad
Fecha: 15/09/2025 14:23:57-0500

1. OBJETIVO

Establecer los requisitos mínimos para los controles criptográficos que garanticen la confidencialidad, integridad, autenticidad y el no repudio de la información manejada por el RENIEC.

2. ÁREA RESPONSABLE

Oficina de Tecnologías de la Información

i. **Unidad de Ingeniería de Software:** Es el encargado de realizar el análisis de la información en tránsito o reposo y definir los controles criptográficos que se deben utilizar dependiendo del tipo de información. También debe generar las llaves criptográficas y las comparte únicamente al personal autorizado del despliegue del proyecto.
ii. **Líder del Equipo de Desarrollo:** Es el encargado de solicitar el soporte para cumplir con los controles criptográficos definidos en el presente documento.

3. ALCANCE

El presente estándar aplica para su uso en la implementación del Sistema Integrado de Identificación y Registro Civil (SIIRC) y constituye además una guía de buenas prácticas para el desarrollo y mantenimiento de los sistemas de información a cargo de la Unidad de Ingeniería de Software (UIS).

4. REQUISITOS

4.1 Técnicas de protección de datos confidenciales

4.1.1 Cifrado

Método que permite aumentar la seguridad de un mensaje o de un archivo mediante la codificación del contenido, de manera que solo pueda leerlo la persona que cuente con la clave adecuada para decodificarlo.
Todos los algoritmos de cifrado son reversibles (siempre que esté autorizado y tenga la clave adecuada).

Cadenas de conexión a base de datos:

La cadena de conexión constituye un dato confidencial y debe almacenarse en un Secret Manager; nunca en código fuente, repositorios ni variables de entorno en texto plano. Este dato confidencial debe proteger mediante cifrado y contar con rotación de credenciales según política. La conexión hacia la base de datos debe realizarse a través de TLS 1.3 o superior.

4.1.1.1 Cifrado simétrico

En un sistema de criptografía simétrica, el remitente y el receptor utilizan dos instancias de la misma clave para el cifrado y descifrado de los datos. Es por ello por lo que la clave tiene doble funcionalidad: cifrar y descifrar.

Se define el algoritmo simétrico estandarizado:

Advanced Encryption Standard (AES)

- Longitud de clave: 256 bits
- Modo de operación: CBC (Cipher Block Chaining)
- Padding: PKCS#7

4.1.1.2 Cifrado asimétrico

En un sistema de criptografía asimétrica, el par de llaves se compone de una clave pública y una clave privada. La clave pública puede ser conocida por todo el mundo y es la que se utiliza para cifrar el mensaje, mientras que la llave privada debe ser conocida y utilizada solo por el propietario para descifrar el mensaje cifrado.

Se define el algoritmo asimétrico estandarizado:

RSA

- Longitud de clave: 2048 bits
- Padding: PKCS#1

4.1.2 Funciones Hash:

Un hash es una función que toma una cadena de longitud variable (un mensaje) y produce un valor de longitud fija denominado valor hash. Las funciones hash no son reversibles y permiten verificar cambios accidentales o maliciosos en los datos.

- **Integridad general.** Utilizar SHA-512 como función de referencia para verificación de integridad de archivos, mensajes y artefactos. Cuando se requiera autenticación del mensaje, emplear HMAC-SHA-512.

- **Contraseñas y secretos derivados**. Debe emplearse un KDF resistente a fuerza bruta, preferentemente Argon2id (recomendado) o bcrypt/scrypt, con parámetros ajustados a la plataforma.

El ámbito de ejecución para el cálculo de hashes/KDF para contraseñas y secretos debe realizarse únicamente en el backend, dentro de un entorno controlado. No se permite realizar hashing/KDF en el cliente (web, móvil o desktop), ni enviar claves o parámetros de KDF al cliente.

4.1.3 Enmascaramiento:

En el enmascaramiento de datos, también conocido como ofuscación de datos, se mantiene el formato original de los datos, modificando únicamente los valores parcialmente. Los datos pueden ser alterados de varias maneras siempre y cuando se asegure que sea imposible la detección o la ingeniería inversa. Las técnicas de enmascaramiento son NO reversibles.

4.1.3.1 Algoritmo de sustitución

Consiste en sustituir caracteres del dato real por un carácter especial para garantizar que el dato sea legible. La sustitución debe realizarse por el carácter asterisco (*) y acorde a lo especificado en el Estándar de protección de datos confidenciales.

4.2 Bibliotecas de cifrado

Todos los productos y servicios desarrollados para el SIIRC que requieren hacer uso de algún algoritmo criptográfico, deberá utilizar la siguiente librería:

- Para el cifrado en frontend Javascript: node-forge
- Para el cifrado en backend Java: Bouncy Castle

El uso de cualquier otra librería para fines criptográficos deberá ser revisada con el equipo de la Unidad de Ingeniería de Software.

4.3 Casos de uso aplicables

4.3.1 Información que requiere cifrado:

a) Información confidencial que requiera ser almacenada en repositorios del RENIEC.
b) Secretos, cualquier información que se quiera tener bajo un control estricto de acceso.
c) Credenciales de autenticación de servicio.
d) Credenciales de usuarios en tránsito y reposo, sí y sólo si estas requieren ser recuperadas como parte del funcionamiento normal del sistema o aplicación. No es habitual recuperar las credenciales en claro, por ende, se deberá utilizar funciones hash.
e) Certificados de autenticación.
f) Información confidencial recuperada de consultas a las bases de datos o servicios, y que requieran ser transmitidos a terceros.
g) Tokens de acceso.
h) Claves de API (Client_secret).

4.3.2 Información que requiere hash:

a) Información en reposo correspondiente a contraseñas de usuarios en sistemas de autenticación.
b) Información sobre la cual se requiera verificar su integridad y comprobar su origen.

4.3.3 Información que requiere enmascaramiento:

a) Información confidencial que requerimos que no sea visible para un usuario o sistema no autorizado y donde no se requiera obtener el valor original.
b) Cuando se requiera mostrar información confidencial a usuarios desde canales no autenticados.

4.4 Consideraciones

a) Cada caso de uso tiene que ser evaluado y/o revisado por la Unidad de Ingeniería de Software, a fin de determinar la técnica de protección que debe ser implementada.
b) Los responsables de generar y resguardar las llaves criptográficas serán el equipo de la Unidad de Ingeniería de Software.
c) Todas las claves simétricas y asimétricas tendrán una vigencia de 2 años. Después del final del periodo de duración de la llave, esta no podrá usarse para generar datos nuevos, pero todavía se podrá utilizar para la lectura de datos cifrados.